

Audit Management — complete module & admin specification

Everything in one report: what the module does, its data model and lifecycle, every end-user screen, the full Admin configuration surface, roles & permissions, AI governance, e-signature & compliance, integrations, and the audit trail.

Audience & purpose. This is the definitive reference for the Audit Management module, serving three readers: the **administrator** who configures it, the **IT/CSV** function that validates and secures it, and **product/engineering** who maintain it. It goes well beyond the end-user guide — exhaustive on the data model, the configurable workflow engine, the role/permission matrix, AI-governance controls, and compliance settings.

Contents

Part 1	Module overview — purpose, capabilities, where it sits	Part 6	Admin configuration — the full surface (diagram + every area)
Part 2	Data model — entities & relationships (diagram)	Part 7	AI governance — agents, models, grounding, redaction
Part 3	Lifecycle — the audit state machine (diagram)	Part 8	E-signature & compliance — 21 CFR Part 11
Part 4	End-user screens — operational flow (summary)	Part 9	Integrations & data
Part 5	Roles & permissions — the RBAC matrix	Part 10	Audit trail & reproducibility

v0.9 DRAFT — labels representative. This report was prepared WITHOUT access to the live application in this revision. Menu names, field names, schema (PK/FK), setting labels, and console layout are **representative** — derived from Hawkeye's known feature set and standard EQMS conventions, accurate in structure and behaviour but to be reconciled against the live build. Italicised / [bracketed] terms are placeholders. In a regulated setting this report is itself a controlled artifact — verify and version-control it before use in validation or training.

What Audit Management does

The Audit Management module runs the full lifecycle of supplier, internal, and for-cause audits — from planning through conducting, findings, reporting, sign-off, and reuse. It is distinguished from a conventional audit tool by three things: **AI agents** that draft the slow work (supplier risk dossiers, risk-weighted questionnaires, findings reports), **public-data fusion** that pulls live FDA/EMA/WHO signals into risk assessment, and a **per-call AI audit trail** that makes every AI output reproducible and defensible.

Core capabilities

Capability	Description
Audit lifecycle engine	Configurable status flow with permission-gated transitions and e-signature sign-off.
Supplier risk dossier (AI)	Supplier Intel agent builds a provenance-tagged risk profile from public regulatory data.
Risk-weighted questionnaire (AI)	Audit Prep agent generates a supplier-specific questionnaire, not a generic checklist.
Evidence capture + Autofill (AI)	Attach evidence; the Autofill agent extracts answers from uploaded documents.
Findings management	Raise, classify, and link findings to CAPAs in the EQMS module.
Report generation (AI)	Report Assembler drafts a cited audit report for human review and e-sign.
Audit trail & reuse	Per-call AI audit trail; completed audits are searchable, exportable, reusable.

Where it sits

Audit Management is one module in the Hawkeye EQMS, sharing the workflow engine, e-signature controls, and audit trail with CAPA, Deviations, Documents, and Change Control. It links to the **Suppliers** module (the master record audited) and to **CAPA** (findings become corrective actions). It is the module most exposed to external parties — customer auditors and regulators — which is why its reporting and audit-trail surfaces are designed for defensibility.

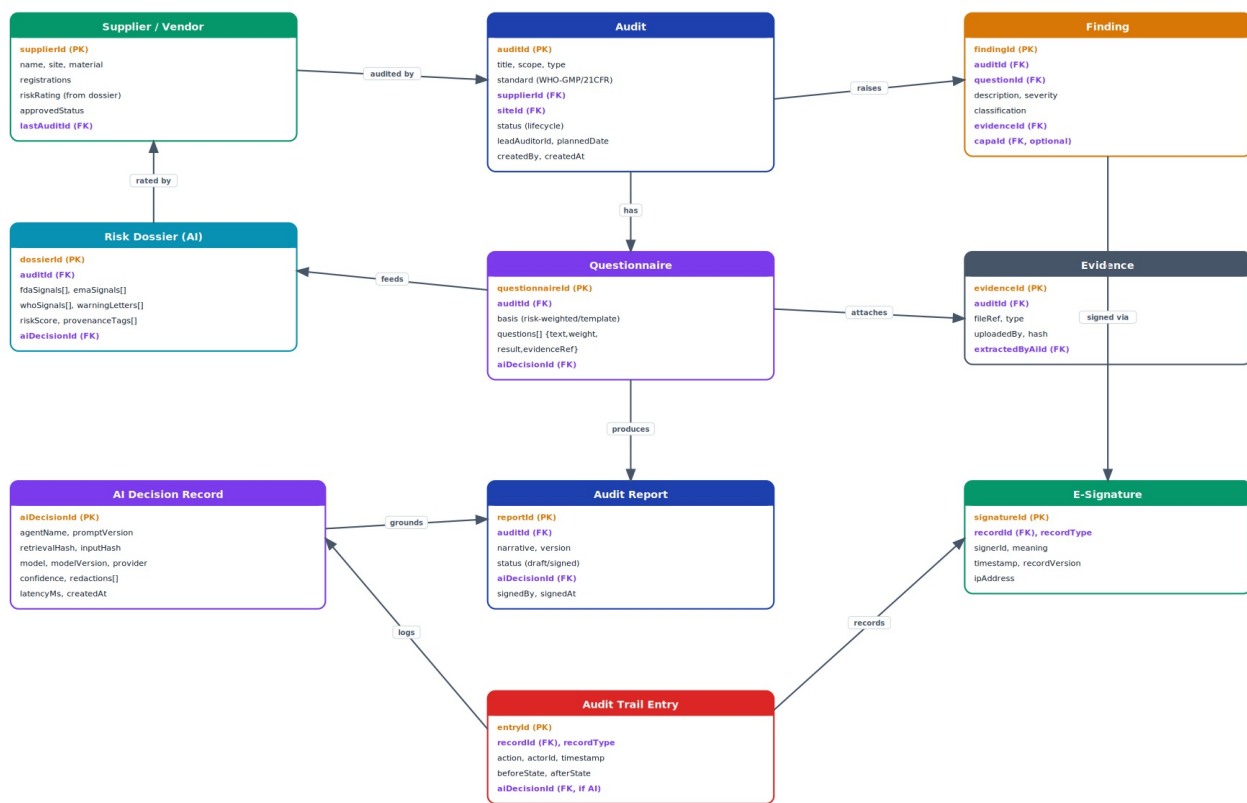
The one-line summary. Audit Management runs the full audit lifecycle with AI that drafts the slow work and public data that informs risk — while a configurable workflow engine, role-based access, enforced human e-signature, and a per-call AI audit trail keep every output controlled, defensible, and reproducible.

Entities and relationships

The module's data model centres on the **Audit** entity, which links to a Supplier, a Risk Dossier, a Questionnaire, Findings, Evidence, and a Report. Two cross-cutting entities — the **AI Decision Record** and the **Audit Trail Entry** — attach to everything, which is what makes the module reproducible.

Audit Management — Entity / Data Model

Core entities and how they relate. Representative schema — verify field names against the live build.



KEY: # = primary key * = foreign key / link

Every entity links to AI Decision (if AI-touched) and to the Audit Trail — that is what makes the module reproducible.

Representative data model from known features + standard EQMS conventions. Confirm exact field names, PK/FK structure, and collections against `codex_backend_01` before external use.

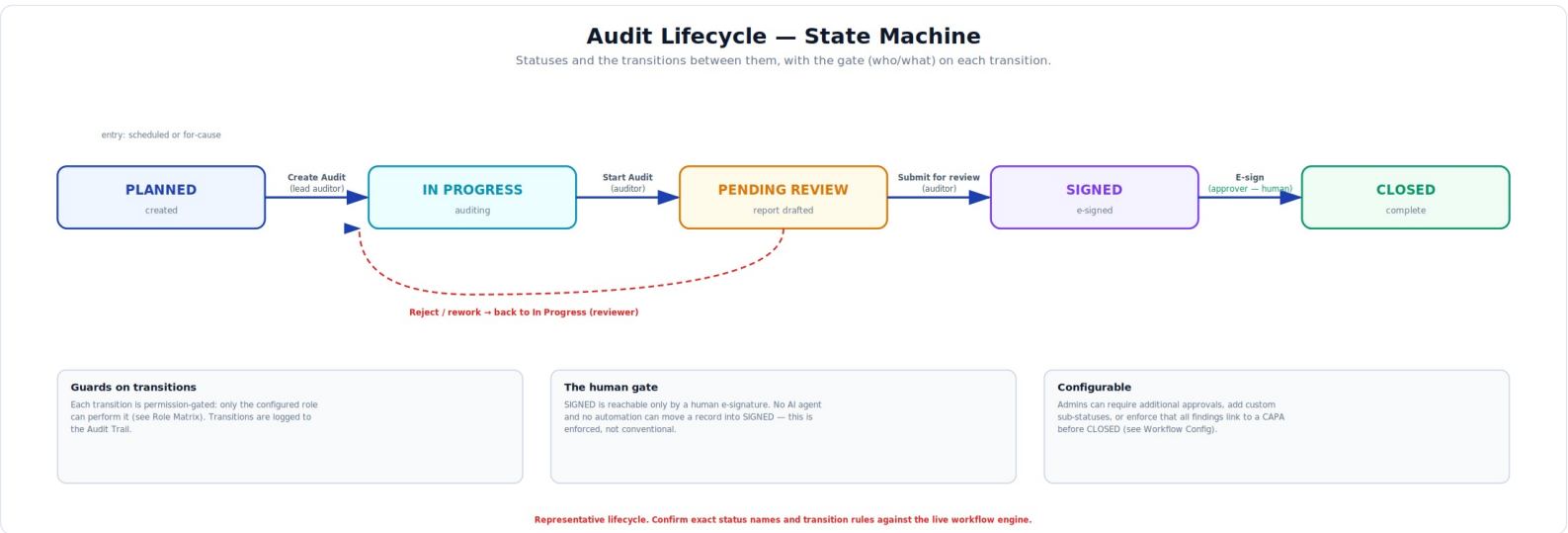
Reading the model

- Audit** is the hub: every other entity links back to it via a foreign key.
- Risk Dossier, Questionnaire, and Report** each carry an `aiDecisionId` linking to the AI Decision Record that produced them — so any AI output can be traced to its exact generation.
- AI Decision Record** stores the reproducibility payload: agent name, prompt version, retrieval hash, model + version, confidence, redactions.
- Audit Trail Entry** logs every action on every record (with before/after state), referencing the AI Decision Record when the action was AI-driven.
- E-Signature** binds a signer, a meaning, a timestamp, and a record version — applied to Reports and (optionally) Findings.

Why the model matters for validation. In a CSV / 21 CFR Part 11 review, the question is always "can you prove who did what, when, and how?" This model answers it structurally: the Audit Trail captures who/what/when, and the AI Decision Record captures how (for AI steps). Confirm the exact collections and field names against `codex_backend_01`, but the structure shown is what supports inspection-readiness.

The audit state machine

An audit moves through five statuses. Each transition is permission-gated (only a configured role can perform it) and logged. The single hard rule: only a human e-signature can move a record into **SIGNED** — no AI agent or automation can.



Transition rules (configurable by admins)

From → To	Gate (role)	Notes
— → Planned	Lead auditor	Entry: scheduled or for-cause
Planned → In Progress	Auditor	Questionnaire becomes the live checklist
In Progress → Pending Review	Auditor	Report drafted; submitted for review
Pending Review → In Progress	Reviewer	Reject / rework path
Pending Review → Signed	Approver (human e-sign)	Hard human gate — enforced
Signed → Closed	Owner	After findings addressed / linked to CAPA

The human gate is enforced, not conventional. Admins can add approval steps, custom sub-statuses, and gates (e.g. "all findings must link to a CAPA before Closed"). But the rule that SIGNED requires a human e-signature is enforced at the platform level — it cannot be configured away. This is foundational to the compliance posture.

The operational flow (summary)

The day-to-day user journey is documented click-by-click in the companion user guide ([hawkeye-guide-audit-management](#)). This part summarises the screen sequence so admins understand what they're configuring. Each screen maps to a lifecycle stage from Part 3.

Screen	Purpose	AI agent
New Audit	Create the audit, set type/supplier/scope	—
Risk tab	Build the supplier risk dossier	Supplier Intel
Questionnaire tab	Generate & edit the questionnaire	Audit Prep
Questionnaire (live)	Conduct: record results + evidence	Autofill
Findings tab	Raise & classify findings; link CAPAs	—
Report tab	Draft, review, e-sign the report	Report Assembler
Audit Trail tab	Inspect how every output was produced	(shows AI records)

Admins control which screens/agents are available per audit type, what fields are mandatory, and which roles can act at each stage (Parts 5–7).

Mapping to configuration. Every row here is configurable: an admin can disable the Risk tab's agent for internal audits, make the questionnaire result field mandatory before submission, or restrict who sees the Report tab. The screens are the surface; Parts 6–7 are the controls behind them.

The RBAC matrix

Access is role-based. Hawkeye ships standard roles which admins can clone and customise. The matrix shows representative default permissions; admins configure the exact grants per role in the Admin console (Part 6).

Capability \ Role	Viewer	Auditor	Lead Auditor	Reviewer	QA Approver	Admin
View audits	✓	✓	✓	✓	✓	✓
Create audit	✗	✗	✓	✗	✗	✓
Run AI agents	✗	✓	✓	✓	✓	✓
Conduct / edit	✗	✓	✓	✗	✗	✓
Raise findings	✗	✓	✓	✓	✗	✓
Submit for review	✗	✓	✓	✗	✗	✓
Reject / rework	✗	✗	✗	✓	✓	✓
E-sign / approve	✗	✗	✗	✗	✓	✗*
Configure module	✗	✗	✗	✗	✗	✓

* Admins configure the system but should not self-approve quality records — separation of duties. Whether Admin can also hold an Approver role is itself a configurable (and auditable) policy decision.

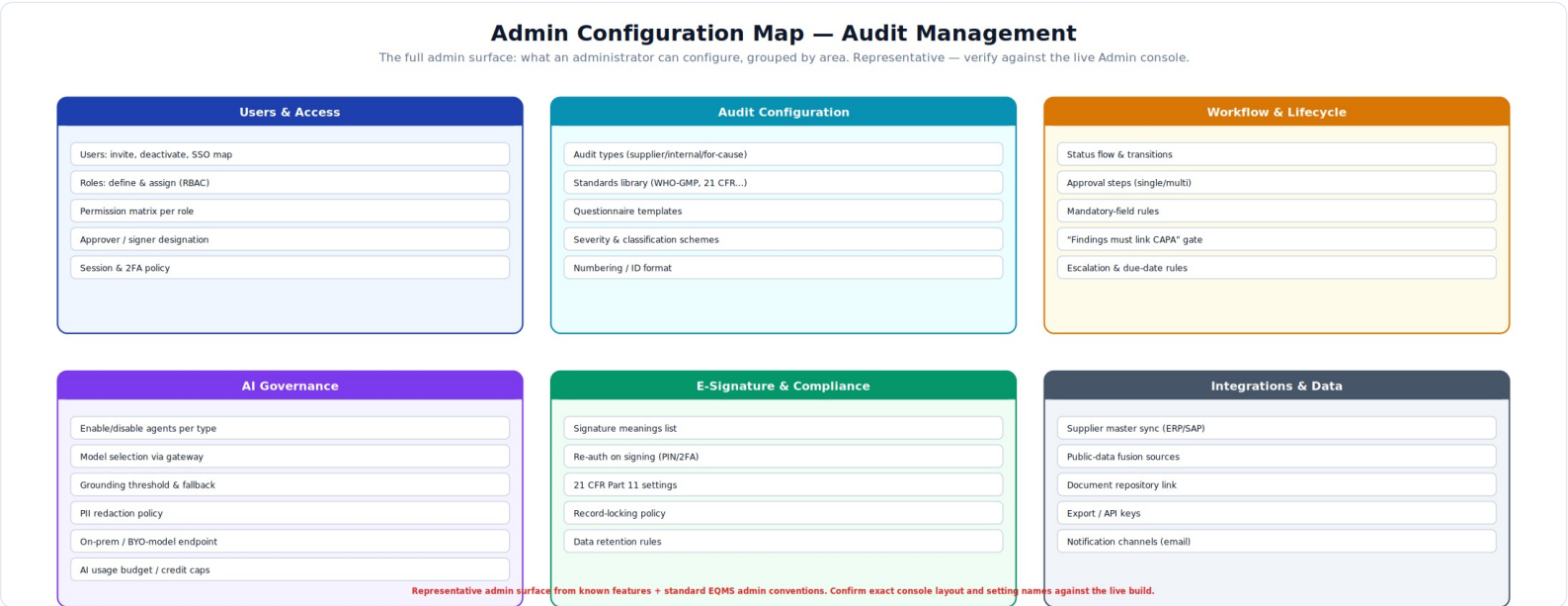
Separation of duties. The matrix encodes separation of duties: the person who conducts an audit is not necessarily the one who approves it, and the system administrator is kept distinct from the quality approver. Admins can tighten this further but should document any role that combines conduct + approval, as inspectors scrutinise it.

Role configuration rules (exhaustive)

- **Standard roles are cloneable.** Start from a shipped role, clone it, and adjust the per-capability grants — never edit a standard role in place (keeps an upgrade-safe baseline).
- **Capabilities are atomic.** Each row in the matrix is an independent grant; a custom role is any combination of them.
- **Scope can be constrained.** A role can be limited to certain audit types, sites, or suppliers (e.g. "Auditor — Site A only").
- **Every grant change is itself audit-logged** — who changed which role's permissions, when.
- **Signer designation is separate** from the e-sign capability: a user must both hold the capability and be designated a valid signer for the record type.

The full admin surface

Everything an administrator can configure for Audit Management, grouped into six areas. The map below is the whole surface; each area is detailed exhaustively below and overleaf.



Admin surface — remaining areas

6.4 • AI Governance (detailed in Part 7)

- **Agent enablement:** turn each agent (Supplier Intel, Audit Prep, Autofill, Report Assembler) on/off per audit type.
- **Model selection:** choose the model per agent via the gateway (cloud or on-prem).
- **Grounding threshold & fallback:** the confidence floor below which the AI returns "insufficient evidence".
- **PII redaction policy:** what is treated as PII and stripped before egress.
- **On-prem / BYO-model endpoint:** point the gateway at a customer-hosted model for sovereignty.
- **AI usage budget / credit caps:** bound AI cost per tenant or audit type.

6.5 • E-Signature & Compliance (detailed in Part 8)

- **Signature meanings:** the selectable list (Approved, Reviewed, Authored).
- **Re-authentication on signing:** require credentials / PIN / 2FA at signing.
- **21 CFR Part 11 settings:** binding, non-repudiation, signature manifestation.
- **Record-locking policy:** how a signed record is locked (new version required to change).
- **Data retention rules:** retention periods, legal hold, archival.

6.6 • Integrations & Data (detailed in Part 9)

- **Supplier master sync (ERP/SAP):** keep Suppliers in sync with the system of record.
- **Public-data fusion sources:** which FDA/EMA/WHO feeds are enabled for Supplier Intel.
- **Document repository link:** connect controlled SOPs/standards from the Documents module.
- **Export / API keys:** manage controlled export and API access.
- **Notification channels:** email (and other) notifications for tasks, approvals, escalations.

Admin best practice. Configure once, document everything, version your configuration. In a regulated setting, the module configuration (workflow rules, role grants, AI settings) is part of the validated state — a change to it may require change control. Treat the Admin console as a controlled surface, not a casual settings page.

Controlling the AI

This is the part most differentiated from a conventional EQMS admin guide, and the part IT/CSV will scrutinise most. Hawkeye gives administrators explicit control over how the AI behaves, where it runs, and how its cost is bounded.

Control	What it does	Admin guidance
Agent enablement	Enable/disable each agent per audit type	Conservative rollout: enable Supplier Intel + Audit Prep first; add Report Assembler once trusted.
Model selection (gateway)	Route each agent to a chosen model	Cheaper model for extraction (Autofill); stronger model for synthesis (Report Assembler).
Grounding threshold	Confidence floor for grounded output	Raise = more conservative (safer, fewer outputs); lower = more forthcoming. The key safety dial.
Fallback behaviour	What happens below threshold	Returns explicit "insufficient evidence" rather than a guess — never disable this.
PII redaction	Strips identifiers before egress	Configure PII classes; enforce even on-prem for defence-in-depth.
Deployment / sovereignty	Cloud, hybrid, or on-prem endpoint	On-prem LLM is maturing — validate end-to-end before production GMP reliance.
AI usage budget	Credit caps per tenant/type	Bound cost and prevent runaway automated usage.

The governance guarantee. No matter how the dials are set, two properties hold and cannot be configured away: every AI output is **grounded-or-fallback** (it never asserts what it can't cite), and the AI **never commits a record** (a human always reviews and e-signs). Admin controls tune behaviour WITHIN these guarantees; they don't remove them.

Verify before external use: (1) whether the tool/agent runtime is MCP-compliant or custom; (2) whether on-prem LLM deployment has run end-to-end or is a validated-but-unproven scaffold. State "available" vs "proven" accurately.

21 CFR Part 11 and the compliance surface

The module is built to support 21 CFR Part 11 / EU Annex 11-style electronic records and signatures. Admins configure the specifics.

Setting	What it controls
Signature meanings	The list of meanings a signer selects (Approved, Reviewed, Authored).
Re-authentication on signing	Require credentials / PIN / 2FA at the moment of signing.
Signature binding	Each signature binds signer identity + meaning + timestamp + record version.
Record locking	Whether/how a signed record is locked against further edits (new version required).
Data retention	How long records and audit trails are retained; legal-hold options.
Audit-trail immutability	The activity log is append-only; configure retention and export.

What makes a signature defensible. A defensible e-signature answers: who signed, what they meant, when, and against which exact version of the record — and proves the record wasn't altered after. The module captures all of this; record integrity is protected by per-record hashing plus the append-only audit trail.

Describe integrity accurately. This is record-level integrity (per-record hashing + append-only trail), **not** a blockchain / chained ledger. Do not claim "blockchain" or "immutable ledger" — say "tamper-evident record integrity with an append-only audit trail."

Connecting to the rest of the stack

Integration	Purpose & notes
Supplier master sync (ERP/SAP)	Keep the Suppliers module in sync with the system of record; scope the specific connector with IT.
Public-data fusion sources	FDA (openFDA, inspections, Warning Letters), EMA EudraGMDP, WHO PQ — the live feeds behind Supplier Intel.
Document repository link	Link controlled SOPs/standards from the Documents module into audits.
Export / API	Export reports (controlled, versioned) and integrate via API; manage API keys here.
Notifications	Email (and other channel) notifications for tasks, approvals, escalations.

Scope integrations honestly. Integration depth varies; do not oversell a specific ERP connector's capabilities. Scope each integration with the customer's IT team and confirm what is pre-built versus what needs configuration.

The inspection-readiness layer

The audit trail is not a feature bolted on — it is structural (Part 2). Every action on every record is logged; every AI step additionally writes an AI Decision Record. Together they let you reconstruct exactly how any audit, dossier, questionnaire, or report came to be.

What's captured

- **Activity log:** every create/edit/transition/sign — actor, timestamp, before/after state.
- **AI decision record:** for each AI step — agent, prompt version, retrieval hash, model + version, provider, confidence, redactions, latency.
- **Signature record:** signer, meaning, timestamp, record version.

How an inspection uses it

When an inspector asks "how did you reach this supplier risk rating?" or "how was this audit report generated?" the administrator or auditor opens the Audit Trail tab, expands the relevant AI step, and shows the exact inputs, sources, and model. That reproducibility is the module's core compliance value.

The whole module in one line. Audit Management runs the full audit lifecycle with AI that drafts the slow work and public data that informs risk — while a configurable workflow engine, role-based access, enforced human e-signature, and a per-call AI audit trail keep every output controlled, defensible, and reproducible. Admins tune behaviour; the compliance guarantees hold regardless.

Final verification notes. All labels, schema, and console layout in this report are representative pending reconciliation with the live build. Standing items to confirm: (1) tool runtime custom vs MCP; (2) on-prem LLM end-to-end vs scaffold; (3) exact data-model field names; (4) console layout/setting names. Treat this report as a controlled document and version it once reconciled. Companions: the end-user click-by-click guide and the EQMS module guide/spec.